



## PLANTILLA REPORTE EJECUTIVO — CIA TRIAD GQM+PRAGMATIC

### Especificación Completa de Presentación PowerPoint para Consejo de Administración

#### 18 Diapositivas · Formato Ejecutivo · Dirigido a C-Suite y Órgano de Gobierno

*"El informe técnico de ciberseguridad que el Consejo nunca lee es el que merecemos;  
el informe que habla de euros, plazos y responsabilidades legales es el que necesitamos.  
Estas 18 diapositivas son ese segundo tipo de informe."*

#### ESPECIFICACIONES GENERALES

| Parámetro          | Valor                                                                                                               |
|--------------------|---------------------------------------------------------------------------------------------------------------------|
| Formato            | PowerPoint (.pptx) / Google Slides / Keynote                                                                        |
| Tamaño diapositiva | 16:9 (1920×1080 px) / Widescreen                                                                                    |
| Paleta de colores  | Azul marino #1B3A5C (corporativo) · Blanco #FFFFFF · Gris #F5F5F5 · Verde #27AE60 · Amarillo #F1C40F · Rojo #E74C3C |
| Tipografía títulos | Calibri Light 28-36pt Bold                                                                                          |
| Tipografía cuerpo  | Calibri 14-18pt Regular                                                                                             |
| Tipografía datos   | Calibri Bold 24-48pt (KPIs)                                                                                         |
| Estilo visual      | Minimalista ejecutivo — sin clipart, sin decoraciones innecesarias                                                  |
| Clasificación      | CONFIDENCIAL — Solo uso interno del Órgano de Gobierno                                                              |

#### ESTRUCTURA DE 18 DIAPOSITIVAS

##### DIAPOSITIVA 01 — PORTADA

**Layout:** Fondo azul marino sólido · Franja blanca horizontal en tercio inferior

## CONTENIDO:

[Centro-superior]

Logotipo organización (placeholder 200x80px)

[Centro]

ESTADO DE LA CIBERSEGURIDAD ORGANIZACIONAL

Marco CIA Triad – GQM + PRAGMATIC

[tamaño 36pt Bold, color blanco]

[Centro-inferior]

[NOMBRE ORGANIZACIÓN]

Período: [Q1-Q4] [AÑO]

Clasificación: CONFIDENCIAL

[tamaño 16pt, color blanco 70%]

[Franja inferior izquierda]

Presentado a: Consejo de Administración / Comité de Auditoría

Fecha: [fecha completa]

Responsable: [CISO / Director de Seguridad]

## DIAPPOSITIVA 02 — AGENDA EJECUTIVA

**Layout:** Dos columnas · Fondo blanco · Barra lateral azul marino

TÍTULO: AGENDA DE LA SESIÓN

[Subtítulo: Tiempo estimado: 30 minutos]

COLUMNA IZQUIERDA — ESTRUCTURA:

- 01 · Resumen Ejecutivo (4 min)
- 02 · Estado IGM-CIA por Pilar (5 min)
- 03 · Indicadores en Zona Crítica (5 min)
- 04 · Análisis de Riesgo y ROSI (8 min)
- 05 · Posición Comparativa España/Sector (3 min)
- 06 · Plan de Acción y Presupuesto (5 min)

COLUMNA DERECHA — MENSAJES CLAVE DE HOY:



[Logro principal del período]



[Riesgo principal a gestionar]



IGM-CIA Global: [X,X / 5,0]



Riesgo cuantificado: [X€M/año]



Inversión requerida: [X€]

[Nota de pie: Este informe se distribuye bajo clasificación CONFIDENCIAL]

## DIAPPOSITIVA 03 — RESUMEN EJECUTIVO (El "Una Página")

**Layout:** Cuatro cuadrantes + KPI central · Fondo gris muy claro

[KPI CENTRAL – grande, centro de la diapositiva]

IGM-CIA GLOBAL

[NÚMERO GRANDE: ej. 3,4 / 5,0]

Nivel: DEFINIDO ●

[Tendencia: ↑ +0,3 vs. trimestre anterior]

[CUADRANTE SUPERIOR IZQUIERDO]

CONFIDENCIALIDAD

IGM\_C: [3,1] ●

Principal gap: MFA Coverage 67%

Acción: Ampliación MFA + Shadow AI

[CUADRANTE SUPERIOR DERECHO]

INTEGRIDAD

IGM\_I: [3,8] ●

Fortaleza: TMPVC en 8 días

Atención: Supply Chain (SBOM 12%)

[CUADRANTE INFERIOR IZQUIERDO]

DISPONIBILIDAD

IGM\_A: [3,4] ●

Uptime: 99,7% (objetivo 99,9%)

Gap: RTO no probado en 3 sistemas

[CUADRANTE INFERIOR DERECHO]

RIESGO FINANCIERO

ALE Portfolio: [€X,XM/año]

ROSI inversión propuesta: [XXX%]

Payback estimado: [X meses]

[PIE DE PÁGINA]

Referencia normativa: ENS RD 311/2022 · NIS2 (UE 2022/2555) · DORA (UE 2022/2554) ·  
RGPD

## DIAPOSITIVA 04 — CONTEXTO: PANORAMA DE AMENAZAS 2025

**Layout:** Visual de amenazas con iconos + estadísticas clave · Fondo oscuro con datos en blanco

TÍTULO: EL CONTEXTO EN QUE OPERAMOS  
[Subtítulo: Datos globales y España 2025]

FILA SUPERIOR – 4 ESTADÍSTICAS CLAVE (cajas de color):

|                                                  |                                                     |                                        |                                         |
|--------------------------------------------------|-----------------------------------------------------|----------------------------------------|-----------------------------------------|
| 122.223<br>Incidentes<br>INCIBE 2025<br>(récord) | \$4,44M<br>Coste medio<br>brecha IBM<br>global 2025 | 392<br>Ransomware<br>en España<br>2025 | 194 días<br>MTTD global<br>Verizon 2025 |
|--------------------------------------------------|-----------------------------------------------------|----------------------------------------|-----------------------------------------|

FILA CENTRAL – VECTORES MÁS FRECUENTES (mapa visual):

- 🔑 Credenciales robadas: 22% de brechas
- 📦 Vulnerabilidades borde: 8× incremento
- 👤 Terceros/Supply chain: 30% de brechas
- 🧑 Ingeniería social: 60% componente humano
- 🤖 IA generativa ofensiva: +35% uso en ataques

MENSAJE CLAVE [caja destacada azul]:

"Las amenazas no esperan a que la organización esté lista.  
Nuestro IGM-CIA de [X,X] nos sitúa en posición [NIVEL] frente a este panorama."

FUENTES: Verizon DBIR 2025 · IBM Cost of Data Breach 2025 · INCIBE 2025 · ENISA Threat Landscape 2025

## DIAPPOSITIVA 05 — MAPA DE CALOR: TODOS LOS INDICADORES

**Layout:** Tabla de calor (heatmap) · 22 indicadores × 3 dimensiones

TÍTULO: ESTADO INTEGRAL – 22 INDICADORES CIA TRIAD

TABLA HEATMAP (formato de semáforos):

CONFIDENCIALIDAD:

MFA Coverage [🟡] | IAM Madurez [🟡] | Cifrado Reposo [🟡] | PQC Cripto [🟠] | DLP [🟡] | Shadow AI [🔴]

INTEGRIDAD:

FIM Coverage [🟡] | TMPVC [🟢] | Supply Chain [🔴] | Firma Digital [🟢] | Logs Integridad [🟡]

DISPONIBILIDAD:

MTTD [🟡] | MTTR/MTTC [🟡] | RTO/RPO [🟡] | Uptime [🟢] | Resiliencia Ransomware [🟡] | Edge Devices [🟡]

CIANA:

Trazabilidad Sesiones [🟡] | Cultura Seguridad [🟡] | Zero Trust Maturity [🔴]

LEYENDA: 🟢 Óptimo (Score 4-5) · 🟡 Aceptable (Score 2-4) · 🔴 Crítico (Score 0-2)

[Nota: Los colores reflejan Score PRAGMATIC-ponderado del período actual]

## DIAPPOSITIVA 06 — DEEP DIVE: PILAR CONFIDENCIALIDAD

**Layout:** Gráfico de barras horizontal + KPIs · Mitad izquierda datos, mitad derecha acciones

## TÍTULO: CONFIDENCIALIDAD – Detalle por Indicador

[GRÁFICO BARRAS HORIZONTAL – izquierda]

Eje Y: Indicadores C-01 a C-06

Eje X: Score 0-5

Barras de color según semáforo

Línea vertical en Score 3 (objetivo mínimo)

Línea vertical en Score 4 (objetivo óptimo)

[ACCIONES PRIORITARIAS – derecha]

● URGENTE:

- Shadow AI: Aprobar política IA en 30 días
- Responsable: DPO + CISO
- Coste: €15.000 (política + formación)

⚠ ATENCIÓN:

- MFA: Ampliar cobertura del 67% al 99%
- Plan: 60 días, 3 fases
- Coste: €45.000 (licencias + integración)

✓ MANTENER:

- Cifrado en reposo: 87% cobertura (continuar)
- DLP: revisar reglas, reducir FP

[KPI RESUMEN INFERIOR]

IGM\_C: 3,1/5,0 · Tendencia: ↑0,2 · Brecha objetivo: 0,9 puntos

## DIAPPOSITIVA 07 — DEEP DIVE: PILAR INTEGRIDAD

**Layout:** Mismo estilo que diapositiva 06

### TÍTULO: INTEGRIDAD – Detalle por Indicador

[GRÁFICO BARRAS HORIZONTAL]

Indicadores I-01 a I-05 con scores actuales

Destacar I-02 (TMPVC) en verde como fortaleza

Destacar I-03 (Supply Chain) en rojo como gap

[DESTACADO ESPECIAL – caja verde]

🏆 FORTALEZA: Tiempo Mediano de Parcheo

TMPVC Críticas: 8 días (objetivo ≤ 7 días)

TMPVC Altas: 14 días (objetivo ≤ 15 días)

Esto nos protege del 54% de exploits de borde documentados

[URGENTE – caja roja]

⚠ BRECHA: Supply Chain / SBOM

SBOM Coverage: 12% de aplicaciones

EU Cyber Resilience Act mandará SBOM en 2027

Acción: Integrar Syft/CycloneDX en pipeline CI/CD

Plazo: Q2-Q3 2025 · Coste: €20.000

[KPI RESUMEN]

IGM\_I: 3,8/5,0 · El pilar más maduro · Mantener TMPVC como referencia

## DIAPPOSITIVA 08 — DEEP DIVE: PILAR DISPONIBILIDAD

**Layout:** Gráfico de barras + timeline de incidentes · Énfasis en MTTD y ransomware

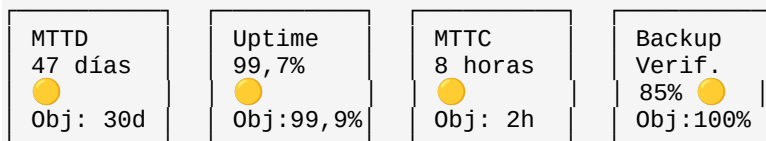
## TÍTULO: DISPONIBILIDAD – Detalle por Indicador

[GRÁFICO BARRAS Y LÍNEA COMBINADO]

Barras: Score PRAGMATIC por indicador A-01 a A-06

Línea: Tendencia histórica Uptime (%) en eje secundario

[KPIs PRINCIPALES – cajas en fila]



[MENSAJE CLAVE – RANSOMWARE]

Con 392 ataques de ransomware en España en 2025 y un coste medio de €2,73M por ataque, un Backup Isolation Score de 1/3 significa que en caso de ataque, nuestros backups TAMBIÉN serían cifrados. Esto no es un riesgo técnico; es un riesgo de balance.

[ACCIÓN REQUERIDA]

✓ Aprobar proyecto de aislamiento de backups: €35.000 · 45 días

## DIAPPOSITIVA 09 — ANÁLISIS DE RIESGO CUANTIFICADO (FAIR)

**Layout:** Tabla de escenarios + gráfico de burbuja ALE vs. Inversión

### TÍTULO: RIESGO CUANTIFICADO EN EUROS – Metodología FAIR

[TABLA PRINCIPAL – escenarios ordenados por ALE]

| Escenario        | ARO | SLE   | ALE/año | Control propuesto         | Inversión | ROSI |
|------------------|-----|-------|---------|---------------------------|-----------|------|
| Ransomware ERP   | 15% | €2,1M | €315K   | Backup airgap + ejercicio | €35K      | 802% |
| Brecha RGPD      | 25% | €1,8M | €450K   | DLP + clasificación datos | €80K      | 463% |
| Credenciales VIP | 20% | €850K | €170K   | MFA phishing-resistant    | €45K      | 278% |
| Supply chain     | 12% | €1,5M | €180K   | SBOM + verificación CI/CD | €20K      | 797% |
| DDoS servicios   | 30% | €400K | €120K   | WAF + CDN redundante      | €60K      | 100% |

TOTAL ALE PORTFOLIO: €1.235.000/año

TOTAL INVERSIÓN PROPUESTA: €240.000

ROSI GLOBAL:  $(€1.235K \times \text{reducción esperada } 65\% \times 3 \text{ años} - €240K) / €240K = 1.003\%$

PAYBACK MEDIO: 2,3 meses

[GRÁFICO BURBUJA]

Eje X: Inversión requerida (€)

Eje Y: ALE reducido (€/año)

Tamaño burbuja: ROSI (%)

[Cada burbuja = un escenario de la tabla]

## DIAPPOSITIVA 10 — POSICIÓN COMPETITIVA: ESPAÑA Y BENCHMARKS

**Layout:** Gráfico de radar comparativo + tabla de posición

## TÍTULO: ¿DÓNDE ESTAMOS RESPECTO AL SECTOR Y AL PAÍS?

[GRÁFICO RADAR – 5 ejes: IGM\_C, IGM\_I, IGM\_A, IGM\_CIANA, PRAGMATIC Avg]

Serie 1: Nuestra organización (azul sólido)

Serie 2: Benchmark sector (verde punteado)

Serie 3: Media España (gris punteado)

Serie 4: Best-in-class (naranja punteado)

[TABLA CONTEXTUAL]

| Benchmark            | IGM-CIA | Nivel         | Fuente          |                       |
|----------------------|---------|---------------|-----------------|-----------------------|
| Nuestra organización | [X,X]   | [Nivel]       | Medición propia |                       |
| Media España PYMES   | ~2,0    | Formativo     | Cisco CRI 2025  |                       |
| Media sector         | [X]     | ~[Y]          | [Nivel]         | ENISA NIS Investments |
| Objetivo NIS2        | ≥ 3,0   | Definido      | NIS2 Art. 21    |                       |
| Best-in-class EU     | ~4,5    | Optimizado    | ENISA 2025      |                       |
| ITU Tier 1 España    | 99,74   | Institucional | ITU GCI 2024    |                       |

[MENSAJE CLAVE]

España es Tier 1 del ITU, pero el 61% de sus empresas son "Formativas" (Cisco CRI 2025).

Nosotros estamos [X posición] respecto a la media sectorial española.

## DIAPPOSITIVA 11 — CUMPLIMIENTO NORMATIVO: SEMÁFORO REGULATORIO

**Layout:** Tabla de semáforo normativo · Enfoque en obligaciones con sanción

### TÍTULO: ESTADO DE CUMPLIMIENTO NORMATIVO

[TABLA DE SEMÁFOROS POR MARCO]

| Marco               | Ámbito aplicación      | Estado      | Brechas identificadas             | Sanción máxima |
|---------------------|------------------------|-------------|-----------------------------------|----------------|
| ENS (RD 311/2022)   | AAPP y proveedores     | ● Parcial   | Op.acc.5, Op.exp.4                |                |
| Administrativa      |                        |             |                                   |                |
| NIS2 (UE 2022/2555) | Esenciales/Importantes | ● Parcial   | Art. 20(2) formación directivos   | 10M€ / 2%      |
| DORA (UE 2022/2554) | Sector financiero      | [Si aplica] | Art. 11 – pruebas TLPT pendientes | Según BDE/CNMV |
| RGPD (UE 2016/679)  | Universal              | ● Cumple    | Cifrado reposo 87% (gap 13%)      | 20M€ / 4%      |
| EU AI Act           | Uso de IA              | ● Gap       | Sin política IA aprobada          | 35M€ / 7%      |
| eIDAS 2             | Firma y autenticación  | ● Parcial   | PKI Health al 94% (6% expirados)  |                |
| Según supervisor    |                        |             |                                   |                |

[OBLIGACIONES URGENTES – caja roja]

⚠ NIS2 Art. 20(2): Formación de directivos – OBLIGATORIA · Sin opción de aplazamiento

⚠ EU AI Act: Política IA para sistemas de alto riesgo – Phased implementation 2025-2026

⚠ NIS2 Art. 23: Proceso de notificación de incidentes en 24h/72h – verificar proceso actual

[NOTA LEGAL]

La responsabilidad personal de los directivos bajo NIS2 Art. 20 no es transferible al equipo técnico.

El desconocimiento de la norma no exime de responsabilidad.

## DIAPPOSITIVA 12 — HALLAZGOS CRÍTICOS: TOP 5 BRECHAS

**Layout:** Cinco tarjetas de hallazgo con formato RAG

TÍTULO: HALLAZGOS PRIORITARIOS — ACCIÓN REQUERIDA DEL CONSEJO

[TARJETA 1 — ROJO]

● Shadow AI sin Gobernanza

Riesgo: Exfiltración de datos confidenciales a servicios externos no evaluados

Evidencia: 0/5 en madurez de política IA (EU AI Act en vigor)

Impacto: Hasta €35M sanción + daño reputacional

Acción: Aprobar política IA y programa de inventario

Coste: €15.000 · Plazo: 30 días

Responsable: [DPO / CISO]

[TARJETA 2 — ROJO]

● Zero Trust Maturity: Nivel Inicial

Riesgo: Movimiento lateral irrestricto en caso de compromiso

Evidencia: Sin microsegmentación en el 70% de segmentos críticos

Impacto: Multiplicador ×3 en alcance de un incidente

Acción: Proyecto de microsegmentación por fases

Coste: €120.000 · Plazo: 12 meses

Responsable: [Arquitecto de red / CISO]

[TARJETA 3 — AMARILLO]

● Formación NIS2 de Directivos Incompleta

Riesgo: Responsabilidad personal de los miembros del Consejo bajo NIS2 Art. 20

Evidencia: [X]% de directivos sin formación en ciberseguridad completada

Impacto: Riesgo legal personal (no corporativo)

Acción: Programa formación ejecutiva NIS2

Coste: €8.000 · Plazo: 60 días

Responsable: [Secretaría del Consejo]

[TARJETA 4 — AMARILLO]

● SBOM Coverage al 12%

Riesgo: Ceguera ante vulnerabilidades en componentes de terceros

Evidencia: 88% aplicaciones sin inventario de componentes

Impacto: EU CRA obligará SBOM en 2027; empezar ahora es ventaja

Acción: Integrar generación SBOM en pipelines CI/CD

Coste: €20.000 · Plazo: 90 días

[TARJETA 5 — AMARILLO]

● Backup Isolation Insuficiente

Riesgo: En un ataque ransomware, backups también serían cifrados

Evidencia: Isolation Score 1/3 (VLAN, no red separada)

Impacto: Sin recuperación sin pago en escenario de ataque completo

Acción: Migrar backups críticos a red aislada

Coste: €35.000 · Plazo: 45 días

## DIAPPOSITIVA 13 — FORTALEZAS: LO QUE FUNCIONA BIEN

**Layout:** Tres tarjetas de fortaleza + mensaje de continuidad



## TÍTULO: FORTALEZAS CONSOLIDADAS – MANTENER Y AMPLIAR

### [TARJETA VERDE 1]

- ✓ **TMPVC – Líderes en gestión de vulnerabilidades**  
8 días para parcheado de CVEs críticos (objetivo  $\leq 7$  días)  
Posición: Top quartile en benchmarks España  
Esta velocidad nos protege del 54% de exploits de borde (Verizon 2025)

### [TARJETA VERDE 2]

- ✓ **Firma Digital – PKI saludable al 94%**  
Cumplimiento eIDAS 2 en procesos críticos  
Timestamps cualificados para no-repudio  
[Solo gap: 6% certificados a renovar en  $< 30$  días → acción automatizable]

### [TARJETA VERDE 3]

- ✓ **Disponibilidad de Servicios – 99,7% uptime**  
Por encima de la media del sector [X%]  
MTTC en incidentes prioritarios: 8 horas (mejora de 40% vs. año anterior)  
Cumplimiento SLA en 97% de períodos

### [MENSAJE CENTRAL]

Estas fortalezas no son accidentes. Son el resultado de inversiones consistentes en [nombre de programas/proyectos específicos].  
Propuesta: Documentarlas formalmente para el próximo informe GRI/ESG de la organización.

## DIAPPOSITIVA 14 — PLAN DE ACCIÓN: MATRIZ IMPACTO/ESFUERZO

**Layout:** Gráfico de burbujas 2×2 (impacto vs. esfuerzo) + tabla de prioridades

## TÍTULO: PLAN DE ACCIÓN – ¿EN QUÉ INVERTIR PRIMERO?

[GRÁFICO 2x2]

Eje X (horizontal): Esfuerzo/Coste (€) – de bajo a alto

Eje Y (vertical): Impacto en IGM-CIA / Reducción de Riesgo – de bajo a alto

Cuadrante SUPERIOR-IZQUIERDO (Quick Wins – HACER AHORA):

- Política IA (€15K,  $\Delta$ IGM +0,3)
- Renovación certificados expirados (€2K,  $\Delta$ IGM +0,1)
- Formación directivos NIS2 (€8K,  $\Delta$ IGM +0,2)

Cuadrante SUPERIOR-DERECHO (Inversión Estratégica – PLANIFICAR):

- Backup isolation (€35K,  $\Delta$ IGM +0,4)
- Microsegmentación ZT (€120K,  $\Delta$ IGM +0,6)
- MFA phishing-resistant (€45K,  $\Delta$ IGM +0,5)

Cuadrante INFERIOR-IZQUIERDO (Fill-ins – CUANDO POSIBLE):

- SBOM en CI/CD (€20K,  $\Delta$ IGM +0,2)
- Log retention review (€5K,  $\Delta$ IGM +0,1)

Cuadrante INFERIOR-DERECHO (Reconsiderar – EVALUAR):

- PQC inventory completo (€80K,  $\Delta$ IGM +0,3) → largo plazo
- DSPM completo (€150K,  $\Delta$ IGM +0,3) → evaluar ROI

[TABLA RESUMEN]

| Acción           | Coste     | ROSI      | $\Delta$ IGM | Plazo | Aprobación requerida  |
|------------------|-----------|-----------|--------------|-------|-----------------------|
| Política IA      | €15K      | N/A       | +0,3         | 30d   | Dirección General     |
| Backup isolation | €35K      | 802%      | +0,4         | 45d   | CIO + CIS0            |
| MFA resiliente   | €45K      | 278%      | +0,5         | 60d   | CIO                   |
| Formación NIS2   | €8K       | Legal     | +0,2         | 60d   | Consejo               |
| SBOM CI/CD       | €20K      | 797%      | +0,2         | 90d   | CTO                   |
| Microsegm. ZT    | €120K     | 415%      | +0,6         | 12m   | Consejo + presupuesto |
| TOTAL            | **€243K** | **~450%** | **+2,2**     |       |                       |

## DIAPPOSITIVA 15 – ROADMAP A 18 MESES

**Layout:** Gantt visual · Tres horizonts temporales

## TÍTULO: ROADMAP DE CIBERSEGURIDAD – 2025-2026

[GANTT VISUAL – simplificado para Consejo]

### HORIZONTE 1 – Quick Wins (Meses 1-3):

|  |                                                    |
|--|----------------------------------------------------|
|  | Política IA Generativa aprobada y comunicada       |
|  | Formación NIS2 órgano directivo completada         |
|  | Renovación certificados expirados (automatización) |
|  | Proceso notificación NIS2 verificado y ensayado    |

### HORIZONTE 2 – Inversión Operacional (Meses 3-9):

|  |                                      |
|--|--------------------------------------|
|  | Backup isolation → red separada      |
|  | MFA phishing-resistant ampliación    |
|  | SBOM integración en CI/CD            |
|  | Ejercicio recuperación ransomware H1 |

### HORIZONTE 3 – Transformación Estratégica (Meses 9-18):

|  |                             |
|--|-----------------------------|
|  | Microsegmentación ZT fase 1 |
|  | DLP + clasificación datos   |
|  | CISA ZT Assessment formal   |
|  | PQC roadmap aprobado        |

### HITOS NORMATIVOS FIJOS:

- Mes 1: ⚡ Notificación NIS2 process: verificación interna
- Mes 6: 📄 Informe DORA testing H1 (si aplica)
- Mes 12: 📊 Revisión anual IGM-CIA + informe Consejo
- Mes 18: 🎯 Objetivo IGM-CIA  $\geq 4,0$  (nivel Gestionado)

[ΔIGM-CIA proyectado]

Actual: [X,X] → Mes 6: [X,X+1,0] → Mes 12: [X,X+1,8] → Mes 18:  $\geq 4,0$

## DIAPPOSITIVA 16 – PRESUPUESTO Y APROBACIONES REQUERIDAS

**Layout:** Tabla de presupuesto + solicitud formal de aprobación

## TÍTULO: SOLICITUD PRESUPUESTARIA Y APROBACIONES

### [TABLA PRESUPUESTO POR HORIZONTE]

| Horizonte       | Proyectos        | CAPEX     | OPEX/año  | Total 18m | Prioridad   |
|-----------------|------------------|-----------|-----------|-----------|-------------|
| H1 (Meses 1-3)  | 4 proyectos      | €28K      | €15K      | €43K      | Urgente     |
| H2 (Meses 3-9)  | 4 proyectos      | €100K     | €35K      | €170K     | Necesario   |
| H3 (Meses 9-18) | 4 proyectos      | €200K     | €80K      | €360K     | Estratégico |
| **TOTAL**       | **12 proyectos** | **€328K** | **€130K** | **€573K** |             |

### [COMPARATIVA CONTEXTO]

Coste total 18 meses: €573.000

ALE Portfolio reducción estimada: €803.000/año × 1,5 años = €1.204.500

VAN 3 años: €1.204.500 × 1,5 - €573.000 = \*\*€1.233.750 neto positivo\*\*

ROSI: 215%

### [APROBACIONES REQUERIDAS HOY]

- ☐ Aprobación presupuesto H1 (€43.000): Dirección General
- ☐ Aprobación inicio proyecto MFA/Backup: CIO + CISO
- ☐ Mandato formación directivos NIS2: Secretaría del Consejo
- ☐ Autorización política IA Generativa: Director General + DPO
- ☐ Aprobación presupuesto H2 (€170.000): Consejo (siguiente sesión)

### [RIESGO DE NO ACTUAR]

Cada mes de retraso en la política IA = riesgo acumulado de €15.000/mes de exposición  
Cada mes sin backup isolation = riesgo acumulado de €26.250/mes (15% × €315K ALE mensual)

## DIAPPOSITIVA 17 — MÉTRICAS DE SEGUIMIENTO PARA EL CONSEJO

**Layout:** Seis KPIs de gobernanza · Simples, comprensibles, sin jerga técnica

## TÍTULO: LOS 6 INDICADORES QUE EL CONSEJO NECESITA CONOCER CADA TRIMESTRE

### [KPI 1 – GRANDE]

IGM-CIA Global: [X,X / 5,0]

"¿Cuán maduro es nuestro programa de seguridad?"

Objetivo trimestral: +0,3 por trimestre

### [KPI 2]

Riesgo cuantificado: €[X]M/año

"¿Cuánto dinero en riesgo tenemos si no actuamos?"

Objetivo: reducir en 30% en 12 meses

### [KPI 3]

Incidentes críticos: [N] en el período

"¿Cuántos incidentes graves hubo y cuál fue su impacto?"

Objetivo: 0 incidentes de nivel crítico

### [KPI 4]

Cumplimiento normativo: [X]%

"¿Estamos cumpliendo las leyes aplicables?"

Objetivo: ≥ 95% en todos los marcos obligatorios

### [KPI 5]

Ejecución del plan: [X]%

"¿Estamos ejecutando lo que aprobamos?"

Objetivo: ≥ 80% de hitos en plazo

### [KPI 6]

Phishing Click Rate: [X]%

"¿Son nuestros empleados conscientes de los riesgos?"

Objetivo: ≤ 5% (actualmente [X]%)

### [NOTA AL CONSEJO]

Estos 6 KPIs serán reportados trimestralmente en sesión del Consejo o Comité de Auditoría.

La fuente de datos es el sistema IGM-CIA GQM+PRAGMATIC auditado por [firma auditora].

## DIAPPOSITIVA 18 — CIERRE Y PRÓXIMOS PASOS

**Layout:** Fondo azul marino · Texto blanco · Llamada a la acción clara

TÍTULO: DECISIONES REQUERIDAS HOY [fecha]

[COLUMNA IZQUIERDA – Resumen de la sesión]

Lo que hemos visto hoy:

- ✓ IGM-CIA Global: [X,X/5,0] – nivel [NIVEL]
- ✓ Riesgo cuantificado: €[X]M/año reducibles con €243K de inversión
- ✓ Brechas críticas: Shadow AI + ZT + Formación directivos
- ✓ Fortalezas: TMPVC, Firma Digital, Uptime
- ✓ Roadmap: 12 proyectos en 18 meses, ROSI >215%

[COLUMNA DERECHA – Decisiones]

Decisiones requeridas:

1. ☐ Aprobación política IA Generativa
2. ☐ Presupuesto H1 €43.000
3. ☐ Mandato formación NIS2 directivos
4. ☐ Autorización proyecto backup isolation
5. ☐ Próxima sesión para aprobación H2

[CENTRO – Fecha siguiente revisión]

Próxima presentación ante Consejo:

[FECHA – en 90 días]

Hito esperado: IGM-CIA ≥ [X,X+0,6]

[PIE]

Elaborado por: [CISO / Director de Seguridad]

Método: GQM+PRAGMATIC CIA Triad Framework v2025

Clasificación: CONFIDENCIAL – Distribución restringida al Consejo

Contacto para preguntas: [email CISO] · [teléfono]

## NOTAS DE DISEÑO Y PERSONALIZACIÓN

### Elementos visuales consistentes en todas las diapositivas

HEADER: Barra azul marino #1B3A5C a 8% del alto total

- Izquierda: Logotipo organización
- Centro: Título de la diapositiva
- Derecha: Número de diapositiva / 18 + clasificación CONFIDENCIAL

FOOTER: Barra gris #F5F5F5 a 4% del alto total

- Izquierda: "CIA Triad GQM+PRAGMATIC Framework v2025"
- Derecha: Fecha y período de reporte

PALETTE COLORES (consistente con semáforos del IGM-CIA):

- Verde #27AE60 – Score ≥ 4 / Cumplimiento
- Amarillo #F1C40F – Score 2-4 / Atención
- Rojo #E74C3C – Score < 2 / Crítico / Urgente
- Azul #2980B9 – Información neutra
- Gris #95A5A6 – Datos secundarios / benchmark externo

### Adaptaciones recomendadas por audiencia

| Audiencia                | Énfasis             | Quitar                   | Añadir                                      |
|--------------------------|---------------------|--------------------------|---------------------------------------------|
| Consejo completo         | Diap. 3, 11, 16, 18 | Detalles técnicos (6-8)  | Implicaciones de responsabilidad personal   |
| Comité de Auditoría      | Diap. 5, 9, 10, 11  | Quick wins operacionales | Detalle de marcos y controles               |
| Comité de Riesgos        | Diap. 9, 10, 14, 15 | Detalles técnicos        | Escenarios adicionales FAIR                 |
| CIO/CTO (equipo técnico) | Diap. 5-8, 14-15    | Marco legal (11)         | Detalles técnicos adicionales por indicador |
| CEO en solo              | Diap. 3, 16, 18     | Todo lo técnico          | Un párrafo de contexto personal             |

*Plantilla Reporte Ejecutivo CIA Triad GQM+PRAGMATIC v2025 · Basada en: ISACA Board Cybersecurity Briefing Guidelines; NACD Director's Handbook on Cyber-Risk Oversight (2024); NIS2 Art. 20 (gobernanza órgano directivo); DORA Art. 5 (ICT risk management); World Economic Forum Principles for Board Governance of Cyber Risk (2024)*